

Narrativa Explicativa del Marco GQM + PRAGMATIC aplicado a Indicadores CMMC / NIS2 / ENS

Versión: 1.0

1. De “controles” a “métricas con propósito”

El universo CMMC / NIST / ENS está plagado de controles, requisitos, apartados y subapartados. Eso está muy bien para auditores y reguladores, pero el día a día de una organización exige responder preguntas más mundanas:

- ¿Estamos mejorando o empeorando?
- ¿Dónde estamos realmente expuestos?
- ¿Qué nos conviene priorizar si sólo podemos hacer tres cosas este año?

El enfoque **GQM + PRAGMATIC** nace para evitar dos errores frecuentes:

1. Medir lo que es fácil medir, en lugar de lo que importa.
2. Inflar cuadros de mando con gráficos tan vistosos como irrelevantes.

2. GQM: del objetivo a la métrica, no al revés

La tentación habitual es empezar por los datos que ya tenemos (“tenemos logs, contemos cosas”) y luego intentar deducir de ahí algún tipo de historia de seguridad. El método **GQM** propone el camino contrario:[web:53][web:56][web:57][web:60][web:66]

3. Goal – Fijar objetivos claros. Ejemplo: “Reducir la probabilidad de compromiso de cuentas críticas mediante un despliegue amplio de MFA.”
4. Question – Preguntar qué debemos saber para saber si avanzamos. Ejemplo: “¿Qué porcentaje de cuentas críticas tiene MFA?” “¿Cuántas excepciones existen?”
5. Metric – Traducir esas preguntas en datos concretos: números, porcentajes, tiempos, tasas.

Este enfoque tiene la virtud de forzar la **trazabilidad**: cada métrica está ahí por una razón clara, ligada a un objetivo de negocio o regulatorio, no sólo por disponibilidad técnica.

3. PRAGMATIC: la criba de la utilidad

No todas las métricas nacen iguales. Algunas son:

- Difíciles de calcular.
- Fáciles de manipular.
- O tan crípticas que sólo las entiende la persona que montó el Excel.

El marco **PRAGMATIC** propone una batería de criterios para evaluar la calidad de cada métrica: que sea **Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente y Rentable**. [web:58][web:61][web:64][web:67]

La idea es simple:

- Si una métrica no ayuda a anticipar problemas, no está conectada con riesgos reales, no conduce a decisiones y además cuesta un mundo obtenerla... quizás sea el momento de dejarla marchar.
- En cambio, las métricas que puntúan alto en varios criterios se convierten en candidatas naturales para cuadros de mando y reporting a alta dirección.

4. Aplicación concreta a indicadores CMMC

Tomemos un ejemplo: el indicador “porcentaje de cuentas críticas con MFA”.

- Goal: Reducir el riesgo de acceso no autorizado a sistemas críticos.
- Question: ¿Hasta qué punto hemos desplegado MFA en las cuentas más sensibles?
- Metric: %_Cuentas_criticas_MFA.

Luego lo pasamos por el tamiz PRAGMATIC:

- Predictivo: un alto porcentaje de MFA reduce la probabilidad de intrusión por robo de credenciales (4/5).
- Relevante: toca directamente un vector de ataque clave (5/5).
- Accionable: la dirección puede establecer objetivos claros (“90 % este año”) (5/5).
- Rentable: dato obtenible a partir de sistemas de identidad sin un esfuerzo épico (4/5).

El resultado es una métrica que no sólo es técnicamente sólida, sino también inteligible para un comité de dirección.

5. Conexión con objetivos nacionales españoles

Los objetivos definidos en el nivel “G” del GQM pueden alinearse explícitamente con:

- Las exigencias de NIS2 sobre gestión de riesgos, medidas técnicas y notificación de incidentes.
- Los requisitos del ENS en materia de organización, operación y protección.
- Las metodologías nacionales de evaluación de ciberresiliencia (por ejemplo, guías metodológicas de evaluación publicadas para España).[web:21][web:63]

Por ejemplo:

- Los objetivos sobre MTTD/MTTR conectan con metas nacionales de reducir el impacto de incidentes notificados a los CSIRT de referencia.
- Los objetivos sobre cadena de suministro resuenan con las preocupaciones regulatorias sobre proveedores TIC críticos y servicios esenciales.

De este modo, las métricas no sólo sirven a la organización, sino también a la construcción de indicadores agregados a nivel sectorial o nacional.

6. Esquema operativo: de GQM + PRAGMATIC al Excel y al PowerPoint

En la práctica, el flujo de trabajo recomendado es:

6. Definir el catálogo de objetivos (G) alineado con CMMC/NIST y los objetivos estratégicos de la organización/país.
7. Derivar las preguntas (Q) que aparecerán en la encuesta y en entrevistas.
8. Derivar las métricas (M) que alimentarán la hoja de cálculo y los cuadros de mando.
9. Evaluar cada métrica con PRAGMATIC y descartar o relegar las de puntuación baja.
10. Incorporar las métricas seleccionadas a:
11. La plantilla Excel de cálculo de IGM y ROI.
12. La plantilla de reporte ejecutivo (resumen gráfico para dirección).
13. Los ejercicios de benchmarking sectorial.

La narrativa, en ese punto, se vuelve coherente: lo que se pregunta en la encuesta está ligado a metas claras, lo que se mide tiene calidad contrastada y lo que se presenta a la dirección no es una sopa de números sino una historia con sentido.

7. Última nota al lector paciente

La combinación GQM + PRAGMATIC no hará desaparecer los incidentes, ni convertirá por sí sola un entorno caótico en una sinfonía de controles perfectos. Pero ofrece:

- Un lenguaje común para hablar de por qué medimos, no sólo de qué medimos.
- Una brújula para distinguir el indicador brillante del ruido estadístico.
- Y una estructura que encaja bien con el espíritu de CMMC, NIST, ENS y NIS2, mucho más exigente en evidencia y trazabilidad que en épocas pasadas.

Si después de esto sigues dispuesto a rediseñar tus métricas, enhorabuena: estás más cerca de tener un cuadro de mando que ilumine, en lugar de deslumbrar.

Fin de la Narrativa Explicativa GQM + PRAGMATIC.